"Same Concepts. Stronger You!"

- [x] Learn Concepts
- [x] Solve Problems
- [x] Build Practical Skills
- [x] Crack Interviews

Knowledge Today Safer Tomorrow!

Cybersecurity Handwritten Notes

Complete Guide

Think Learn Practice Stay Secure

Small Steps Big Security!

Concepts + Practice + Interview Prep

From Basics to Real-World



Hack Learn Defend Repeat

1	Cybersecurity Basics + CIA Triad
2	Threats, Vulnerabilities + Attack Types
3	Risk Management Fundamentals
4	Risk Assessment + Risk Analysis
5	Security Policies + Governance
6	IAM + Authentication + Authorization
7	Network + Endpoint Security
8	Cryptography + Data Security
9	Cloud + Application Security
10	Security Monitoring + Incident Response
11	Security Frameworks + Compliance + Risk Treatment
12	Cybersecurity Cheat Sheet + Top 100 Interview Questions



Safer Digital World!



Not Just Notes... A Safer You!



Secure Build Grow!



"Consistent Learning Builds a Safer Tomorrow"

Cybersecurity is a Mindset Not a Tool!

@codedsoul_05

Learn Protect Build Grow

1. Cybersecurity Basics + CIA Triad

Security Today A Safer Tomorrow !

What is Cybersecurity ?

Cybersecurity is the practice of protecting systems, networks, applications, data and users from digital threats, attacks and unauthorized access. It ensures the confidentiality, integrity and availability of information.

> " Prevent. Detect. Respond. Recover. "

Why is Cybersecurity Important ?

- Protects sensitive data (personal, financial, business)
- Prevents unauthorized access and cyber attacks
- Ensures business continuity and trust
- Required due to increasing digitalization and cyber threats
- Helps organizations meet legal and compliance requirements

Key Terms

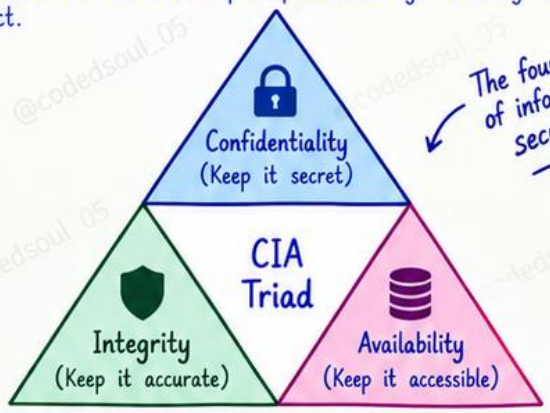
Term	Meaning
Asset	Anything valuable (data, system, people, etc.)
Threat	Potential cause of harm
Vulnerability	Weakness that can be exploited
Risk	Likelihood and impact of a threat
Exploit	Technique used to take advantage of a vulnerability
Attack	Intentional attempt to compromise a system
Mitigation	Steps to reduce risk
Incident	A security event that affects systems or data

Types of Cybersecurity Threats

- **Malware** Malicious software (virus, worm, trojan, ransomware)
- Phishing Tricking users to steal information
- Social Engineering Manipulating people
- DDoS Overwhelming a system with traffic
- Insider Threat Threat from within the organization
- Zero-Day Attack Exploiting unknown vulnerabilities
- Credential Theft Stealing usernames and passwords
- Advanced Persistent Threat (APT) Long-term, targeted attacks

The CIA Triad

The CIA Triad is the fundamental model of information security It defines the three core principles that cybersecurity aims to protect.



The foundation of information security !

Confidentiality

- Ensures that information is only accessible to authorized users.
- Prevents unauthorized access and data leakage.
- Examples: Encryption, Access Control, MFA

Integrity

- Ensures that data is accurate, complete and not tampered with.
- Detects and prevents unauthorized modification.
- Examples: Hashing, Digital Signatures, Checksums

Availability

- Ensures that information and systems are available when needed by authorized users.
- Prevents downtime and disruption.
- Examples: Backup & Recovery, Redundancy, Disaster Recovery

Other Security Principles (Extended)

- Authentication – Verify the identity of a user or system
- Authorization – Define what an authenticated user can do
- Accountability – Track and log actions (audit)
- Non-repudiation – Prevent denial of actions performed
- Privacy – Protect personal and sensitive information

Real World Examples

Scenario	Which Principle ?
Encrypting customer data	Confidentiality
Preventing unauthorized file changes	Integrity
Using backup servers for uptime	Availability
Multi-factor authentication (MFA)	Confidentiality
Audit logs for user actions	Accountability
Digital signatures for software	Integrity
Disaster recovery plan	Availability

Small Steps Big Security !

Same Concepts Stronger You !

Know The Threats Stay One Step Ahead !

2. Threats, Vulnerabilities + Attack Types

Same Concepts Stronger You !

1. What is a Threat ?

- A threat is any potential cause of an unwanted incident that can harm a system, organization or data.

> "A threat is a possibility, not a guarantee."

Types of Threats

Type	Examples
Natural Threats	Fire, Flood, Earthquake, Power failure
Human Threats	Insider misuse, Human error
Intentional Threats	Hackers, Cyber criminals, Nation-state actors
Environmental Threats	Hardware failure, System malfunction

2. What is a Vulnerability ?

- A vulnerability is a weakness in a system, application, network or process that can be exploited by a threat.

> "A vulnerability is a weakness that can be exploited."

Common Vulnerabilities

Type	Examples
Software Vulnerabilities	Unpatched software, bugs
Configuration Issues	Default credentials, open ports
Design Flaws	Weak architecture, insecure logic
Human Factors	Lack of training, social engineering
Physical Vulnerabilities	Unsecured devices, open server rooms

3. Threat vs Vulnerability vs Risk

Term	Meaning
Threat	Potential cause of harm
Vulnerability	Weakness that can be exploited
Risk	Likelihood and impact of a threat exploiting a vulnerability

Example:
A hacker (threat) exploits an unpatched server (vulnerability) which leads to data breach (risk).

4. Types of Attacks

Attack Type	Description
Malware	Malicious software (virus, worm, trojan, ransomware)
Phishing	Tricking users to steal sensitive information
Social Engineering	Manipulating people into revealing confidential data
DoS / DDoS	Overwhelming a system with traffic
Man-in-the-Middle	Intercepting communication between two parties
Password Attacks	Brute force, dictionary, credential stuffing
Injection Attacks	SQL Injection, Command Injection
Zero-Day Attack	Exploiting unknown vulnerabilities
Insider Threat	Malicious or unintentional actions by insiders
Advanced Persistent Threat	Long-term, targeted attacks (usually by nation-states)

5. Common Malware Types

Type	Description
Virus	Attaches to files and spreads when executed
Worm	Self-replicates over networks
Trojan	Looks legitimate but performs malicious actions
Ransomware	Encrypts data and demands a ransom
Spyware	Secretly collects user information
Adware	Displays unwanted advertisements
Rootkit	Gains unauthorized control of a system
Bot / Botnet	Infected devices controlled remotely

6. Attack Lifecycle (Kill Chain)

1 Reconnaissance	2 Weaponization	3 Delivery	4 Exploitation	5 Installation	6 Command & Control	7 Actions on Objectives
Gather information	Create malicious payload	Deliver via email, web, etc.	Exploit vulnerability	Install malware	Maintain access (remotely)	Steal data, modify, disrupt

7. Mitigation Techniques

- Keep systems and software updated
- Use strong passwords and multi-factor authentication
- Implement firewalls and intrusion detection systems (IDS/IPS)
- Provide security awareness training
- Follow the principle of least privilege
- Regularly back up data
- Monitor and log activities
- Conduct vulnerability assessments and penetration testing

8. Key Takeaways

- Threats exploit vulnerabilities
- Not all vulnerabilities are exploited, but they increase risk
- Attacks can be prevented or mitigated with the right controls
- Human factor is one of the biggest security risks
- Stay updated about new and evolving threats

Be Aware Be Prepared Be Safer !

Note :
You cannot stop all threats,
but you can reduce vulnerabilities and minimize risk.

Security Starts With You !

Identify
Assess
Manage
Grow Secure!

3. Risk Management Fundamentals

Manage
Risks
Secure
Tomorrow!

1. What is Risk Management ?

- Risk management is the process of identifying, assessing, prioritizing and managing risks to minimize their impact on an organization's objectives.

> " Right risks, managed well, enable growth.
> Unmanaged risks can destroy it. "

2. Key Concepts

Term	Meaning
Risk	Possibility of a threat exploiting a vulnerability and causing harm.
Asset	Anything valuable to the organization (data, systems, people, reputation, etc.)
Threat	Potential cause of an unwanted incident.
Vulnerability	Weakness that can be exploited by a threat.
Likelihood	Chance of a risk occurring.
Impact	Magnitude of loss or damage if the risk occurs.
Risk Appetite	Amount of risk an organization is willing to accept.
Risk Tolerance	Acceptable variation within the risk appetite.
Control	Measure to reduce likelihood or impact of a risk.

3. Risk Management Process

Identify Risks → Find and list potential risks

Assess Risks → Analyze likelihood and impact

Treat Risks → Apply controls to reduce risk

Monitor and Review → Track risks and update regularly

Communicate and Report → Keep stakeholders informed

Risk management is a continuous and iterative process.

4. Risk vs Issue vs Incident

Term	Meaning
Risk	Potential future event that may cause harm.
Issue	An existing problem that needs to be addressed.
Incident	A risk that has already occurred.
Example	Risk: Data breach may occur Issue: Outdated firewall Incident: Actual data breach happened

5. Types of Risks

Type	Description
Strategic Risk	Related to business strategy and long-term goals
Operational Risk	Related to day-to-day operations (process, people, systems)
Financial Risk	Related to financial loss
Compliance Risk	Related to laws, regulations and standards
Reputational Risk	Related to brand image and trust
Cybersecurity Risk	Related to digital threats and data security
Third-Party Risk	Related to vendors, partners and external service providers
Environmental Risk	Related to natural disasters and physical events

6. Risk Treatment Options

Avoid	Eliminate the risk by stopping the activity.
Mitigate	Reduce likelihood or impact (use controls).
Transfer	Shift the risk to a third party (e.g. insurance).
Accept	Acknowledge the risk and monitor it (when cost of control > potential loss).

7. Risk Matrix (Likelihood vs Impact)

Impact \ Likelihood	Very Low	Low	Medium	High	Very High
Very High	Medium	Medium	High	High	Critical
High	Medium	Medium	High	Critical	Critical
Medium	Low	Medium	High	High	Critical
Low	Low	Low	Medium	High	High
Very Low	Low	Low	Medium	Medium	High

8. Key Takeaways

- Identify and understand your assets, threats and vulnerabilities
- Assess risks using likelihood and impact
- Apply appropriate risk treatment options
- Monitor and review risks continuously
- Align risk management with business objectives
- Involve all stakeholders and maintain clear communication
- Risk management is not about eliminating all risks, but about making informed decisions

> " Manage risks today,
> for a safer tomorrow. "

Same Risks, Smarter Decisions!

Risk Aware Future Ready!

Analyze
Assess
Prioritize
Stay Secure !

4. Risk Assessment + Risk Analysis

Identify
Risks
Reduce
Impact
Build Resilience !

What is Risk Assessment ?

- Risk assessment is the process of identifying, analyzing and evaluating risks to an organization's assets, systems, people and operations.
- It helps in understanding what could go wrong, how likely it is and what the potential impact would be.

> " Know your risks before they become incidents. "

What is Risk Analysis ?

- Risk analysis is a part of risk assessment.
- It involves analyzing the identified risks to determine their likelihood and impact.
- Helps in prioritizing risks and deciding the appropriate treatment or mitigation streategies.

> " Analyze today, prevent tomorrow. "

Risk Assessment Process

1. **Identify Assets & Risks** — Find what needs to be protected and what could go wrong.
2. **Analyze Risks** — Determine likelihood and impact.
3. **Evaluate Risks** — Compare with risk criteria to prioritize.
4. **Treat Risks** — Choose mitigation strategies (avoid, reduce, transfer, accept).
5. **Monitor & Review** — Track risks regularly and update as needed.

Key Steps in Risk Analysis

1	Identify Threats	What could happen ?
2	Identify Vulnerabilities	What are the weaknesses ?
3	Analyze Likelihood	How likely is it to happen ?
4	Analyze Impact	What would be the damage ?
5	Determine Risk Level	Use a risk matrix or scoring.
6	Prioritize Risks	Focus on high and critical risks.

Methods for Risk Assessment / Analysis

Method	Description
Qualitative Analysis	Uses expert judgment (High / Medium / Low)
Quantitative Analysis	Uses numerical values and calculations
Semi-quantitative Analysis	Combination of both qualitative and quantitative
Scenario Analysis	Analyzes specific what-if scenarios
Threat Modeling	Identifies threats and potential attack paths
FAIR (Factor Analysis of Information Risk)	Quantifies risk in financial terms

Risk Matrix (Likelihood vs Impact)

Impact \ Likelihood →	Very Low	Low	Medium	High	Very High
Very High	Medium	High	High	Critical	Critical
High	Low	Medium	High	High	Critical
Medium	Low	Low	Medium	High	High
Low	Low	Low	Low	Medium	High
Very Low	Low	Low	Low	Medium	Medium

Risk Treatment Options

Option	Description
Avoid	Eliminate the risk by stopping the activity.
Mitigate / Reduce	Implement controls to reduce likelihood or impact.
Transfer	Shift the risk to a third party (e.g., insurance).
Accept	Acknowledge the risk if it is within tolerance.

Example: Risk Analysis

Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level
Customer Data	Data Breach	Weak Access Control	High	High	Critical
Web Server	Malware	Unpatched Software	Medium	High	High
Employee Laptop	Theft	No Encryption	Medium	Medium	Medium
Network	DDoS Attack	Insufficient Rate Limiting	High	Medium	High

Key Takeaways

- Risk assessment identifies and evaluates risks.
- Risk analysis determines likelihood and impact.
- Use a structured process and risk matrix.
- Prioritize and treat high-risk items.
- Review and update regularly.

> " Measure the risks, Manage the future. "

Same
Process.
Safer
Tomorrow !

Good Policies Stronger Security !

5. Security Policies + Governance

Right Governance Builds Trust

1. What are Security Policies ?

- Security policies are formal, documented rules and guidelines that define how an organization protects its information, systems and assets.
- They communicate management's expectations regarding security and acceptable behavior.
- Policies help ensure consistency, compliance and risk reduction.

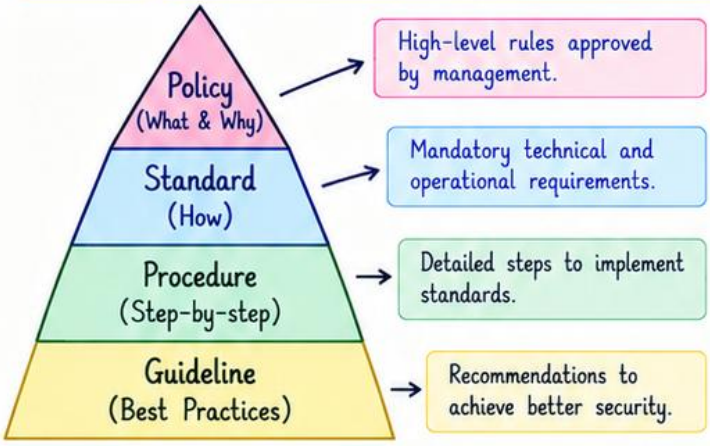
"A good security policy turns security from an option into a habit."

2. What is Governance ?

- Security governance is the overall framework of leadership, structures, processes and accountability to ensure information security aligns with business goals.
- It defines who makes decisions, who is responsible and how security is managed across the organization.
- It ensures the right policies, processes and controls are in place and are followed.

"Governance makes security a business enabler, not just a technical function."

3. Policy Framework Structure



4. Types of Security Policies

Policy Type	Purpose / Coverage
Information Security Policy	Overall security objectives and principles
Access Control Policy	Defines who can access what
Data Protection Policy	Protection of sensitive and personal data
Acceptable Use Policy	Guidelines for authorized use of systems
Email and Internet Policy	Rules for email, web and online activities
Incident Response Policy	How to detect, respond and recover
Physical Security Policy	Protection of physical assets and facilities
Third-Party / Vendor Policy	Security requirements for external partners
Business Continuity Policy	Ensure continuity during disruptions

5. Key Principles of Governance

- **Accountability** — Clear roles and responsibilities
- **Transparency** — Visibility in decision-making
- **Compliance** — Meet legal, regulatory and industry requirements
- **Risk-Based** — Focus on high-risk areas
- **Continuous Improvement** — Regularly review and enhance

6. Governance Framework (Typical Structure)



7. Common Frameworks & Standards

Framework / Standard	Focus Area
ISO/IEC 27001	Information security management system (ISMS)
NIST Cybersecurity Framework	Identify, Protect, Detect, Respond, Recover
COBIT	IT governance and management
ITIL	IT service management (governance + operations)
PCI DSS	Payment card data security
GDPR	Data privacy and protection (regulatory)
SOC 2	Security, availability, confidentiality, etc.

8. Key Takeaways

- Policies define the rules, governance ensures they are followed.
- Clear roles and responsibilities are essential.
- Well-defined policies reduce risk and ensure compliance.
- Governance aligns security with business objectives.
- Use recognized frameworks to build a strong security program.
- Regularly review and update policies.

"Strong policies. Clear governance. A safer tomorrow."

Policy today Peace tomorrow !

People Process Technology ! Security

Right People Right Access Greater Security !

6. IAM + Authentication + Authorization

Control Access Protect Data Build Trust !

1. What is Identity and Access Management (IAM) ?

- IAM is a framework of policies, processes and technologies used to manage digital identities and control access to resources (systems, applications, data).
- It ensures the right people have the right access at the right time for the right reasons.
- Helps improve security, compliance and operational efficiency.

"Manage identities. Minimize risk. Enable productivity."

2. Key Components of IAM

Identities	Authentication	Authorization	Access Management	Monitoring & Auditing
Users, groups, service accounts, devices	Prove who you are	Define what you can do	Policies, roles, permissions	Track and review access activities

3. Authentication

- Authentication is the process of verifying the identity of a user, device or system.
- It answers the question: "Who are you?"

Common Authentication Methods

Method	Example
Something you know	Password, PIN
Something you have	Smartphone, Hardware Token
Something you are	Biometrics (Fingerprint, Face ID)
Something you do	Behavior (Typing pattern, Location)
Multi-Factor Authentication (MFA)	Combination (e.g. Password + OTP)

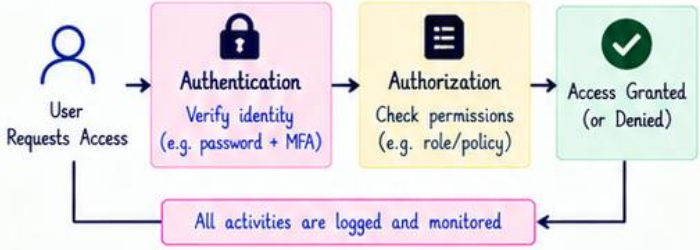
4. Authorization

- Authorization is the process of determining what an authenticated user is allowed to do.
- It answers the question: "What are you allowed to do?"

Common Authorization Models

Model	Description
RBAC (Role-Based Access Control)	Access based on roles (e.g. Admin, User)
ABAC (Attribute-Based Access Control)	Access based on attributes (e.g. department, location, time)
ACL (Access Control List)	Permissions assigned to specific users or groups
PBAC (Policy-Based Access Control)	Access based on policies and rules
ReBAC (Relationship-Based Access Control)	Access based on relationships (e.g. manager → employee)

5. How IAM Works (Flow)



6. IAM Best Practices

Least Privilege Maximum Security !

- Follow the principle of least privilege (PoLP)
- Use multi-factor authentication (MFA)
- Regularly review and revoke unnecessary access
- Use strong password policies and avoid shared accounts
- Implement role-based or attribute-based access control
- Monitor and audit access logs regularly
- Manage privileged accounts separately (PAM)
- Automate provisioning and deprovisioning (Joiner-Mover-Leaver process)
- Ensure compliance with regulatory requirements

7. Common IAM Terminology

Term	Meaning
Identity	A unique representation of a user, device or system
Credential	Information used for authentication (e.g. password, token)
Role	A set of permissions (e.g. Admin, Read Only)
Permission	Specific action allowed (e.g. read, write, delete)
Single Sign-On (SSO)	One login for multiple applications
Federation	Sharing identity across trusted systems (e.g. SAML, OAuth)
Provisioning	Creating and assigning access to users
Deprovisioning	Removing access when no longer needed
PAM (Privileged Access Mgmt)	Managing high-privilege accounts
Audit Log	Record of access and activities

8. Real World Examples

Scenario	How IAM Helps
Employee joins the company	Create identity, assign role, grant access
Employee changes role	Update permissions based on new role
Employee leaves the company	Revoke all access immediately
Remote employee login	Use MFA and SSO for secure access
Third-party vendor access	Provide limited, time-bound access
Access to sensitive data	Allow only authorized users (e.g. via ABAC)
Compliance audit	Provide logs and reports of access activities

"Right Identity. Right Access. A Safer Tomorrow."

Secure Identities Stronger Organizations !

Secure Networks ! Secure Devices ! Safer Tomorrow !

7. Network + Endpoint Security

Same Concepts Stronger You !

1. What is Network Security ?

- Network security is the practice of protecting networks, devices and data from unauthorized access, attacks and misuse.
- It includes technologies, policies and processes to monitor and control incoming and outgoing traffic.
- Goal: Ensure confidentiality, integrity, availability and safe communication across the network.

"If the network is secure, the business stays connected."

2. Network Security Components

Firewalls	IDS / IPS	Switches / Routers	VPN	Network Segmentation
Control incoming and outgoing traffic	Detect and prevent malicious activity	Manage and route network traffic	Secure remote access	Divide network into smaller, secure zones

3. Common Network Security Threats

Threat	Description
DDoS Attack	Floods the network with traffic to make it unavailable
Man-in-the-Middle (MitM)	Intercepts communication between two parties
ARP Spoofing	Fakes MAC address to intercept data
DNS Poisoning	Redirects users to malicious sites
Port Scanning	Finds open ports to exploit
Malware / Botnets	Compromises devices and spreads through network
Unsecured Wi-Fi	Allows unauthorized access

4. Network Security Best Practices

- ✅ Use firewalls and IDS/IPS
- ✅ Implement network segmentation (e.g. VLANs)
- ✅ Use VPN for remote access
- ✅ Keep network devices updated
- ✅ Disable unused ports and services
- ✅ Use strong encryption (e.g. WPA3 for Wi-Fi)
- ✅ Monitor network traffic and logs
- ✅ Implement access control (least privilege)
- ✅ Regular vulnerability scanning and penetration testing

Monitor Detect Prevent Respond !

5. What is Endpoint Security ?

- Endpoint security protects individual devices (endpoints) such as laptops, desktops, mobiles, servers and IoT devices from threats.
- It prevents unauthorized access, malware infections and data leaks.
- It includes a combination of software, policies and monitoring tools.

"Every device is a potential entry point. Secure your endpoints."

6. Endpoint Security Components

Antivirus / Anti-Malware	EDR (Endpoint Detection & Response)	Device Management	Encryption	Patch Management
Detect and remove malicious software	Monitor, detect and respond to threats	Manage and enforce security policies	Protect data on devices	Keep OS and applications updated

7. Common Endpoint Threats

Threat	Description
Malware (Virus, Trojan, Ransomware)	Infects device, steals or encrypts data
Phishing	Tricks users into installing malware or sharing data
Insider Threat	Malicious or accidental misuse by employees
Lost / Stolen Devices	Physical loss leading to data breach
Unpatched Software	Exploits known vulnerabilities
USB / Removable Media	Spreads malware through external devices
Social Engineering	Manipulates users to gain access

8. Endpoint Security Best Practices

- ✅ Use updated antivirus/EDR solutions
- ✅ Keep OS, applications and firmware patched
- ✅ Enable device encryption (e.g. BitLocker, FileVault)
- ✅ Implement device access controls (PIN, biometrics)
- ✅ Use MDM (Mobile Device Management) for company devices
- ✅ Disable unnecessary USB ports and external devices
- ✅ Educate users about phishing and social engineering
- ✅ Monitor endpoint activity and logs
- ✅ Enforce remote wipe for lost or stolen devices

Secure Every Endpoint !

9. Network vs Endpoint Security

Aspect	Network Security	Endpoint Security
Focus	Protects the network and traffic	Protects individual devices
Example Devices	Firewalls, Routers, Switches, IDS/IPS	Laptops, Desktops, Mobiles, Servers
Main Goal	Secure communication & data flow	Prevent device compromise
Common Threats	DDoS, MitM, Port Scanning, DNS attacks	Malware, Phishing, Lost devices
Key Tools	Firewalls, VPN, IDS/IPS, SIEM	Antivirus, EDR, MDM, Encryption
Scope	Entire network infrastructure	Individual endpoints

10. Key Takeaways

- ✅ Network and endpoint security work together
- ✅ Both are essential for complete organizational security
- ✅ Use multiple layers of defense (defense in depth)
- ✅ Keep monitoring, updating and educating users
- ✅ A single unprotected device can compromise the entire network

"Secure the network. Protect the endpoints. Build a stronger, safer tomorrow."

People | Process | Technology | Security !

Protect Data Today Build a Safer Tomorrow !

8. Cryptography + Data Security

Data is the new currency Protect it !

1. What is Cryptography ?

- Cryptography is the practice of securing information by converting it into an unreadable format (ciphertext) so that only authorized parties can read it (plaintext).
- It ensures confidentiality, integrity, authentication and non-repudiation of data.
- Used everywhere – websites (HTTPS), banking, messaging, storage, etc.

" Cryptography turns data into a secret, and trust into a system. "

2. Goals of Cryptography

Confidentiality
Ensure data is not accessible to unauthorized users.

Integrity
Ensure data is not altered during transmission or storage.

Authentication
Verify the identity of the sender/receiver.

Non-Repudiation
Ensure the sender cannot deny sending the data later.

3. Types of Cryptography

Symmetric Encryption
- Same key for encryption and decryption
- Fast and efficient
- Examples: AES, DES, 3DES
- Used for large data

Asymmetric Encryption
- Two keys: Public key and Private key
- Slower but more secure
- Examples: RSA, ECC
- Used for key exchange, digital signatures

Hash Functions
- Convert data into a fixed-size hash value
- One-way (cannot be reversed)
- Examples: SHA-256, SHA-3, MD5 (deprecated)
- Used for integrity verification

4. Common Algorithms

Type	Algorithm	Key Size	Use Case
Symmetric	AES	128 / 256 bits	Widely used, secure
Symmetric	DES (legacy)	56 bits	Older systems (not secure)
Symmetric	3DES	168 bits	Legacy, better than DES
Asymmetric	RSA	2048 / 4096 bits	Secure communication
Asymmetric	ECC	256 bits	Used in modern systems (mobile, TLS)
Hash	SHA-256	256 bits	Data integrity
Hash	SHA-3	256 bits	Next-generation hashing
Hash	MD5	128 bits	Deprecated (vulnerable)

5. How Encryption Works ? (Simplified)



Same key for symmetric encryption | Different keys for asymmetric encryption

6. What is Data Security ?

- Data security is the practice of protecting data from unauthorized access, use, disclosure, alteration or destruction throughout its lifecycle.
- It includes people, processes and technologies to ensure sensitive data remains safe.

" Secure the data, secure the business. "

7. Data Security Measures

- Encryption (at rest & in transit)
- Access Controls (least privilege)
- Data Classification (sensitive, confidential, public)
- Data Loss Prevention (DLP)
- Secure Backup & Recovery
- Monitoring & Auditing (track access and changes)

8. Data Security Best Practices

- [x] Encrypt sensitive data (at rest and in transit)
- [x] Use strong access controls and least privilege
- [x] Classify and label data properly
- [x] Implement Data Loss Prevention (DLP)
- [x] Regularly backup important data
- [x] Monitor and audit data access
- [x] Secure data in cloud and third-party environments
- [x] Ensure secure data deletion (data sanitization)
- [x] Follow compliance requirements (e.g. GDPR, HIPAA, ISO 27001)

Data Security is everyone's responsibility !

9. Cryptography vs Data Security

Aspect	Cryptography	Data Security
Focus	Mathematical techniques	Broader protection of data
Scope	Encryption, hashing, keys	People, process, technology, policies
Purpose	Secure data content	Protect data throughout lifecycle
Examples	AES, RSA, SHA-256	Access control, DLP, backup, monitoring
Part of	A component of data security	Overall data protection strategy

10. Key Takeaways

- [x] Cryptography secures data using algorithms and keys.
- [x] Data security is a broader concept that includes people, processes and tools.
- [x] Encryption, access control and monitoring are critical.
- [x] Always follow best practices and compliance requirements.
- [x] Protecting data builds trust and ensures long-term business success.

" Data protection today, a brighter tomorrow. "

Secure Data Stronger Future !

Secure Clouds Build Safer Applications !

9. Cloud + Application Security

Same Skills Bigger Opportunities ! ☺

1. What is Cloud Security ?

- Cloud security is the set of policies, technologies, controls and best practices to protect data, applications and infrastructure in cloud environments (e.g. AWS, Azure, GCP).
- It ensures confidentiality, integrity, availability and compliance in shared, multi-tenant environments.
- It covers people, process and technology.

> " Same security principles, different environment. "

2. Shared Responsibility Model

Security in cloud is a shared responsibility between the Cloud Provider and the Customer.

Layer	Cloud Provider Responsibility	Customer Responsibility
Physical Infrastructure	Data centers, hardware, network, virtualization	–
Infrastructure (IaaS)	Compute, storage, networking	OS, data, applications, access management
Platform (PaaS)	Runtime, middleware, OS	Applications, data, configuration
Software (SaaS)	Application, OS, infrastructure	Data, user access, settings, usage

Security in the cloud is a shared journey !

3. Key Cloud Security Challenges

- **Misconfiguration** — Public storage, open security groups, weak IAM policies
- **Identity & Access Management** — Excessive permissions, credential theft
- **Data Protection** — Data leaks, improper encryption
- **Insecure APIs** — Exposed APIs, weak authentication
- **Compliance & Privacy** — Meeting regulatory requirements (e.g. GDPR, HIPAA)
- **Shared Responsibility** — Lack of clarity on who secures what

4. Cloud Security Best Practices

- ✅ Follow the principle of least privilege (PoLP)
- ✅ Use strong IAM policies and MFA
- ✅ Encrypt data at rest and in transit
- ✅ Regularly monitor and audit (CloudTrail, Azure Monitor)
- ✅ Use security groups, firewalls and network segmentation
- ✅ Enable logging and centralized monitoring (SIEM)
- ✅ Use automated security tools (e.g. AWS GuardDuty, Azure Security Center)
- ✅ Regularly patch and update resources
- ✅ Follow compliance frameworks (ISO 27001, SOC 2, GDPR)

Configure Monitor Automate Stay Secure !

5. What is Application Security ?

- Application security is the practice of protecting software applications from threats throughout the Software Development Lifecycle (SDLC).
- It focuses on identifying, preventing and fixing vulnerabilities in the code, design and runtime environment.
- Goal: Build secure applications that can resist attacks and protect user data.

> " Security should be built in, not bolted on. "

6. Common Application Security Threats

Threat	Description
OWASP Top 10	Common web application risks (see next section)
Injection Attacks	SQL Injection, NoSQL Injection, Command Injection
Cross-Site Scripting (XSS)	Injecting malicious scripts into web pages
Cross-Site Request Forgery (CSRF)	Tricking users into unwanted actions
Broken Authentication	Weak session management, credential stuffing
Insecure Direct Object References	Accessing unauthorized data
Security Misconfiguration	Default settings, unnecessary services
Vulnerable Components	Using outdated libraries and frameworks
Sensitive Data Exposure	Storing or transmitting data without encryption
Insufficient Logging & Monitoring	Lack of detection and response mechanisms

7. OWASP Top 10 (2021)

1	Broken Access Control	6	Vulnerable and Outdated Components
2	Cryptographic Failures	7	Identification and Authentication Failures
3	Injection	8	Software and Data Integrity Failures
4	Insecure Design	9	Security Logging and Monitoring Failures
5	Security Misconfiguration	10	Server-Side Request Forgery (SSRF)

8. Application Security Best Practices

- ✅ Follow secure coding practices
- ✅ Use input validation and output encoding
- ✅ Implement authentication and authorization properly
- ✅ Keep dependencies and frameworks updated
- ✅ Conduct regular security testing (SAST, DAST, SCA)
- ✅ Implement logging and monitoring
- ✅ Follow OWASP guidelines
- ✅ Use Web Application Firewall (WAF)
- ✅ Include security in CI/CD pipeline (DevSecOps)

Write Test Fix Repeat Build Secure !

9. Cloud vs Application Security (Quick Compare)

Aspect	Cloud Security	Application Security
Focus	Infrastructure, platform, data	Software applications
Main Risks	Misconfiguration, IAM, data leaks	Code vulnerabilities, OWASP Top 10
Tools	Cloud-native tools (GuardDuty, Azure Security Center, CloudTrail)	SAST, DAST, SCA, WAF
Responsibility	Shared (Provider + Customer)	Development, Security and Operations teams
Goal	Secure cloud environment	Build and run secure applications

10. Key Takeaways

- ✅ Cloud and application security are both critical and complementary.
- ✅ Understand the shared responsibility model in cloud.
- ✅ Follow security best practices and use the right tools.
- ✅ Prevent common application vulnerabilities (OWASP Top 10).
- ✅ Security is a continuous process, not a one-time activity.
- ✅ Build security into every layer – from infrastructure to code.

> " Secure the cloud. Build secure apps. Create a safer digital world. "

Learn ! Apply ! Stay Secure !

Detect
Respond
Recover
Stronger !

10. Security Monitoring + Incident Response

Stay Aware
Stay Prepared
Stay Secure

1. What is Security Monitoring ?

- Security monitoring is the continuous process of collecting, analysing and monitoring logs, events and activities to detect suspicious or malicious behavior.
- It helps identify threats in real time and enables a faster response.
- Uses tools like SIEM, EDR, IDS/IPS, log management and threat intelligence.

"You can't stop what you can't see."

2. What is Incident Response ?

- Incident response is the structured process of handling and recovering from a security incident.
- It aims to minimize damage, restore normal operations and prevent future incidents.
- It includes preparation, detection, analysis, containment, eradication and recovery.

"Be ready before the incident, not after it."

3. Key Security Monitoring Components

Log Collection	Log Analysis	Alerting	Monitoring Tools	Threat Intelligence
Collect logs from systems, networks, applications and cloud services.	Analyse events to find suspicious patterns.	Generate alerts for potential threats.	Use SIEM, EDR, NDR, IDS/IPS and SOAR.	Use internal and external threat data for better detection.

4. Incident Response Lifecycle (NIST)

Preparation	Detection & Analysis	Containment	Eradication	Recovery	Lessons Learned
Build plan, tools, team and policies	Identify and analyse the incident	Stop the spread and limit the impact	Remove the threat from systems	Restore normal operations	Review and improve to prevent future incidents

Respond → Recover → Grow Stronger

5. Common Security Monitoring Tools

Tool	Purpose
SIEM (e.g. Splunk, Sentinel)	Collect and analyse logs, generate alerts
EDR (e.g. CrowdStrike)	Detect and respond to endpoint threats
IDS/IPS (e.g. Snort, Suricata)	Monitor and block network threats
NDR (e.g. Darktrace)	Detect unusual network behaviour
Log Management (e.g. ELK)	Store and search logs
SOAR (e.g. Cortex XSOAR)	Automate incident response tasks
Threat Intelligence (e.g. MISP)	Get latest threat indicators

6. Common Incident Types

Incident Type	Description
Malware / Ransomware	Malicious software that encrypts or steals data
Phishing	Attempt to steal credentials or sensitive data
Data Breach	Unauthorized access to sensitive information
Insider Threat	Malicious or accidental actions by internal users
DDoS Attack	Floods systems with traffic to make them unavailable
Account Takeover	Unauthorized access to user accounts
Web Application Attack	Exploits in web apps (e.g. SQL injection, XSS)
Privilege Escalation	Gaining higher access than intended
Misconfiguration	Security settings not configured properly

7. Best Practices

- Monitor all critical systems (network, endpoints, cloud, applications)
- Use centralized logging and a SIEM solution
- Set up meaningful alerts and tune them regularly
- Keep threat intelligence feeds updated
- Implement EDR and network monitoring
- Have a documented and tested incident response plan
- Run regular security drills and simulations
- Ensure proper log retention and forensic readiness
- Work closely with IT, SecOps and management teams

Detect
Respond
Learn
Repeat !

8. Key Metrics to Track

Metric	Description
MTTD (Mean Time to Detect)	Average time to detect an incident
MTTR (Mean Time to Respond)	Average time to contain and resolve
Number of Incidents	Total security incidents over time
False Positive Rate	Percentage of incorrect alerts
Dwell Time	Time an attacker stays undetected
Incident Severity	Distribution of low, medium, high, critical incidents
Response Effectiveness	How well incidents are handled
System Coverage	Percentage of systems being monitored
Compliance Status	Alignment with regulatory requirements

9. Security Monitoring vs Incident Response

Aspect	Security Monitoring	Incident Response
Focus	Continuous detection	Handling and recovery
Goal	Identify threats early	Minimize impact and restore services
Time	Real time / Ongoing	During and after an incident
Tools	SIEM, EDR, IDS/IPS, NDR	IR Plan, SOAR, Forensic Tools
Output	Alerts and insights	Containment, eradication, recovery
Scope	Proactive and continuous	Reactive and structured

10. Key Takeaways

- You can't protect what you don't monitor.
- Early detection saves time, money and reputation.
- Have a tested incident response plan.
- Monitoring and incident response work together.
- Learn from every incident and improve.
- People, process and technology are all important.
- Stay proactive, stay prepared, stay secure.

"Detect threats. Respond with confidence. Build a safer tomorrow."

Security
Today
A Safer Tomorrow !

Standards
Guide
Govern
Stay Secure !

11. Security Frameworks + Compliance + Risk Treatment

Compliance
Today
A Safer
Tomorrow !

1. What are Security Frameworks ?

- Security frameworks are structured guidelines and best practices to help organizations manage security risks, implement controls and improve overall security posture.
- They provide a common language, processes and control sets to build, operate and measure security programs.
- Examples: NIST, ISO 27001, CIS Controls, COBIT, etc.

"Frameworks turn security from theory into action."

2. Why Compliance Matters ?

- Compliance ensures that organizations follow legal, regulatory and industry specific requirements.
- It helps build trust, avoid penalties and protect customer data.
- Compliance is not just a checkbox; it drives better security practices and risk management.

"Compliance builds trust. Security keeps it."

3. Popular Security Frameworks

NIST Cybersecurity Framework
Identify, Protect, Detect, Respond, Recover (IPDRR)

ISO 27001
Information Security Management System (ISMS)

CIS Controls
Prioritized set of security best practices

COBIT
Governance and management of enterprise IT

PCI DSS
Payment card data security for cardholder data

SOC 2
Trust, security, availability, confidentiality and privacy

4. Framework Comparison (Quick View)

Framework	Focus Area	Used By	Key Benefit
NIST CSF	Risk management	All organizations	Simple and flexible
ISO 27001	ISMS	Global	International standard
CIS Controls	Technical controls	All sizes	Practical and actionable
COBIT	IT governance	Enterprises	Aligns business and IT
PCI DSS	Payment data	Organizations handling card data	Protects cardholder data
SOC 2	Trust and assurance	SaaS / Service providers	Builds customer trust

5. What is Risk Treatment ?

- Risk treatment is the process of deciding how to handle identified risks.
- After assessing and analyzing the risk, we choose the best response to reduce, eliminate or accept the risk.
- It ensures resources are used effectively to bring risks to an acceptable level.

"Identify risks. Choose actions. Stay in control."

6. Risk Treatment Options

Mitigate
Reduce the likelihood or impact of the risk (e.g. implement controls).

Avoid
Eliminate the risk by not doing the risky activity (e.g. change process).

Transfer
Shift the risk to another party (e.g. insurance, outsourcing).

Accept
Accept the risk if it is within risk appetite and monitor it.

"Not all risks can be eliminated, but all risks can be managed."

7. Compliance Examples

Regulation / Standard	Applies To	Key Requirement
GDPR	EU (any org handling EU data)	Data privacy, user consent, right to be forgotten
HIPAA	Healthcare (US)	Protects patient health information
PCI DSS	Payment card industry	Secure handling of cardholder data
ISO 27001	Global	Establish, implement and maintain ISMS
SOX	Public companies (US)	Financial data security and integrity
RBI Guidelines	Banks & Financial (India)	Data protection and cybersecurity
IT Act 2000	India	Legal framework for digital security

8. Risk Management Process (End-to-End)

Identify Risks — Find and understand potential risks

Assess Risks — Analyze likelihood and impact

Treat Risks — Apply mitigation, avoid, transfer or accept

Monitor & Review — Track risks and effectiveness of controls

Communicate & Report — Keep stakeholders informed

Continuous Improvement

9. Security Governance and Roles

Role	Responsibility
Board / Management	Set direction, risk appetite and ensure compliance
CISO	Lead security strategy and implementation
Risk Owner	Manage specific risks and ensure treatment
Compliance Officer	Ensure regulatory and legal compliance
Security Team	Implement and monitor controls
Internal Auditor	Assess effectiveness and report gaps
All Employees	Follow security policies and report incidents

10. Key Takeaways

- Security frameworks provide structure and guidance.
- Compliance ensures legal and regulatory requirements are met.
- Risk treatment helps manage and reduce risks to an acceptable level.
- All three work together for a strong security program.
- Choose the right framework for your organization.
- Continuously monitor, review and improve.
- People, process and technology are equally important.

Govern
Comply
Mitigate
Grow

"Right framework. Strong compliance. Smarter risk treatment.
A safer, stronger tomorrow."

Know the Standards
Manage the Risks
Build a Safer Future !

Learn
Prepare
Practice
Get Hired !

12. Cybersecurity Cheat Sheet + Top 100 Interview Questions

Same
Concepts
Bigger
Opportunities !

1. Cybersecurity Cheat Sheet (Quick Reference)

Key concepts, terms and commands at a glance.

CIA Triad
Confidentiality
Integrity
Availability

AAA
Authentication
Authorization
Accounting

Firewall
Controls incoming and outgoing traffic

VPN
Secure connection over public network

SIEM
Collect, analyze and correlate security logs

IAM
Manage users, roles and permissions

Encryption
Protects data (at rest and in transit)

Hashing
One-way function (e.g. SHA-256)

IDS / IPS
Detects / prevents malicious activity

MFA
Adds extra layer of security

2. Important Commands (Cheat Sheet)

Useful commands for daily security tasks (Linux/Windows).

Task	Linux Command	Windows Command
Check IP address	ip a / ifconfig	ipconfig
Check open ports	netstat -tuln / ss -tuln	netstat -ano
View running processes	ps aux	tasklist
Check system logs	tail -f /var/log/syslog	eventvwr
Test network connectivity	ping, traceroute	ping, tracert
DNS lookup	nslookup, dig	nslookup
Check file integrity	sha256sum filename	certutil -hashfile filename SHA256
Find files	find / -name filename	dir /s filename
Check firewall rules	iptables -L	netsh advfirewall show all
Monitor real-time traffic	tcpdump	Get-NetTCPConnection

3. Common Ports & Protocols

Key ports and protocols to remember.

Port	Protocol	Use Case
20/21	FTP	File transfer
22	SSH	Secure remote login
23	Telnet	(Insecure) remote login
25	SMTP	Email sending
53	DNS	Domain name resolution
80	HTTP	Web traffic (unencrypted)
443	HTTPS	Web traffic (encrypted)
3389	RDP	Remote desktop (Windows)
8080	HTTP (Alt)	Common alternative web port

4. Common Attacks (Quick List)

Be aware. Be prepared.

- **Phishing** – trick users into sharing data
- **Malware** – malicious software
- **Ransomware** – encrypts data for ransom
- **DDoS** – floods system with traffic
- **SQL Injection** – inject malicious SQL
- **XSS** – inject scripts into web pages
- **Man-in-the-Middle** – intercepts data
- **Brute Force** – guesses passwords
- **Privilege Escalation** – gain higher access
- **Insider Threat** – misuse of internal access

5. Security Best Practices

Simple habits make a big difference.

- Use strong passwords and enable MFA
- Keep systems, software and patches up to date
- Follow least privilege (PoLP)
- Encrypt sensitive data (at rest and in transit)
- Regularly monitor logs and alerts
- Implement network segmentation
- Take regular backups and test recovery
- Follow secure coding practices (OWASP)
- Conduct regular vulnerability assessments
- Be aware of phishing and social engineering

6. Key Tools (Category Wise)

Popular tools used in the industry.

Category	Popular Tools
Network Security	Wireshark, Nmap, Suricata, Snort
Endpoint Security	CrowdStrike, Microsoft Defender, EDR
SIEM	Splunk, ELK Stack, QRadar, Sentinel
Vulnerability Scanning	Nessus, OpenVAS, Qualys
Web Security	Burp Suite, OWASP ZAP, Nikto
Cloud Security	AWS GuardDuty, Azure Sentinel, Prisma Cloud
Compliance / GRC	ServiceNow, LogicGate, Archer
Forensics	Autopsy, Volatility, FTK
Threat Intelligence	MISP, VirusTotal, AlienVault OTX

7. Security Frameworks & Standards

Know the key frameworks.

Framework / Standard	Focus Area
NIST	Security framework & risk management
ISO 27001	Information security management
CIS Controls	Practical security controls
SOC 2	Trust and compliance (service orgs)
PCI DSS	Payment card data security
GDPR	Data privacy and protection
HIPAA	Healthcare data security
COBIT	IT governance and management
ITIL	IT service management

8. Incident Response (Quick Steps)

Follow a structured approach.

1. **Prepare** – policies, tools, team
2. **Detect** – identify and analyze
3. **Contain** – limit the impact
4. **Eradicate** – remove the threat
5. **Recover** – restore normal operations
6. **Learn** – review and improve

9. Top 100 Cybersecurity Interview Questions

Covers concepts, tools, scenarios and real-world questions.

1	What is cybersecurity?	91	How do you handle a security incident?
2	Explain CIA triad.	92	What is threat hunting?
3	What is the difference between IDS and IPS?	93	Explain zero trust architecture.
4	What is a firewall and how does it work?	94	How do you secure cloud environments?
5	Explain symmetric vs asymmetric encryption.	95	What are common cloud security risks?
6	What is MFA and why is it important?	96	How do you ensure compliance (e.g. GDPR)?
7	What is phishing? How can we prevent it?	97	Explain risk assessment vs risk treatment.
8	Explain SQL injection and its mitigation.	98	How would you design a secure system?
9	What is XSS and how to prevent it?	99	What are the key skills for a SOC analyst?
10	What is a VPN and how does it work?	100	Where do you see cybersecurity in 5 years?

10. Key Takeaways

Remember these for success.

- Understand the basics and build strong fundamentals.
- Be hands-on with tools and real-world scenarios.
- Know frameworks, compliance and risk management.
- Think like an attacker and a defender.
- Keep learning – cybersecurity is an evolving field.
- Practice interview questions and explain concepts clearly.
- Stay curious, stay updated, stay secure.

"Knowledge protects you. Preparation empowers you. Cybersecurity builds a safer tomorrow."

More
Knowledge
Stronger You !

@codedsoul_05

Secure Skills
Better Opportunities !